
감사결과 보고서

- 테마감사 -

2025. 12.

한국체육산업개발주식회사

감 사 실

목 차

I . 감사실시 개요	1
II . 감사결과	2
1. 감사결과 총괄	2
2. 감사결과 처분요구 사항	2
(1) 전자문서 공람 처리 및 관리체계 미흡	3
(2) 개인정보보호시스템별 접근권한 관리 개선 필요	8
(3) 정보보안 관련 모니터링 소홀	12

I. 감사실시 개요

1. 감사배경 및 목적

이번 감사는 감사규정 제4조(감사의 종류) 및 2025년도 감사계획에 의거하여 실시하는 감사로서 업무시스템 내 정보보안(개인정보)의 통제절차 환경 진단을 통해 부정위험을 선제적으로 식별하고 적극적인 대응방안을 발굴함으로써 내부통제 체계를 강화하기 위해 정보보안·개인정보보호 관련 관리의 적정성을 점검하는데 그 목적을 두었다.

2. 감사중점 및 대상¹⁾

이번 감사는 2022. 11. 1.부터 2025. 10. 31.까지 시행한 정보보안·개인정보 취급 업무 전반을 대상으로 감사하였다. 구체적으로 업무시스템 내 정보보안(개인정보) 관련 접근권한 부여 및 관리, 처리절차 등 내부통제절차에 대해 점검하였고, 회사 내규 준수 여부를 점검하여 제도개선 과제를 발굴하는데 감사 중점을 두었다.

3. 감사기간 및 인원

이번 감사는 2025. 11. 24.부터 2025. 12. 5.까지 총 10일간 감사실 인원 7명(연인원 70명)을 투입하여 실지 감사를 하였다.

4. 감사결과 처리

감사 과정의 공정성 및 투명성 제고를 위해 참여 감사인 전원이 감사 시작 전 제척회피 자가진단을 시행하고 청렴서약서를 제출하였으며 감사 종료 후에는 청렴윤리의식 자가진단을 시행하였다. 또한 처분의 객관성을 강화하고 피감부서의 수용도를 제고하고자 실지감사 종료 후 감사보고서 사전 적정성 검토 회의를 개최한 후 감사결과를 최종 확정하였다.

1) '25년 4월 공단종합감사시 내부통제 전반에 대한 감사 시행(운영지침 개정 및 리스크 식별, 평가, 교육, 훈련방안 마련 등 처분요구)에 따라 정보보안 및 개인정보보호 취급 분야 중점 감사(중복감사 제외)

II. 감사결과

1. 감사결과 총괄

감사결과 도출된 지적사항은 아래 표와 같이 개선요구 2건, 권고 1건, 통보 1건, 현지조치 1건 등 총 5건이다.

감사결과 처분요구 현황

구분	합계	개 선	권 고	통 보	현지조치
건수	5	2	1	1	1

□ 감사결과 확인된 주요 문제점의 세부내용은 다음과 같다.

① 전자문서 공람 처리 및 관리체계 미흡

- 전자문서 공람 및 열람에 대한 처리 절차, 기준, 방식 등에 관한 세부 운영 지침 등이 필요하나 이루어지지 않아, 문서관리 규정 및 지침 개정 필요
- 개인정보가 포함된 1등급 문서 관리를 위한 전자문서 시스템 개선 요구

② 개인정보보호시스템별 접근권한 관리 개선 필요

- 「개인정보보호법」에 따라 개인정보시스템별 접근권한을 업무별로 최소화하여야 하나, 접근권한의 기준 및 범위가 명확하지 않아 개선이 필요
- 접근권한과 관련하여 내부통제를 강화할 수 있는 방안 마련 검토 요구

③ 정보보안 관련 모니터링 소홀

- 「국가정보보안기본지침」에 따라 수립한 정보보안 업무 추진계획 관련 운영중인 방화벽 정책 및 자산목록 미현행화 등 관리 소홀에 따른 현지조치

2. 감사결과 처분요구 사항(명세 붙임)

연번	제 목	처분종류	관계부서
1	전자문서 공람 처리 및 관리체계 미흡	개 선	●★
		권 고	●★□□●
2	개인정보보호시스템별 접근권한 관리 개선 필요	개 선	●★□□●
		통 보	●★□□●
3	정보보안 관련 모니터링 소홀	현지조치	●★□□●

한국체육산업개발주식회사 감사실장

개 선 · 권 고

제 목 전자문서 공람 처리 및 관리체계 미흡

관 계 부 서 ★□, ●★□

내 용

1. 업무개요

★□□은 「문서규정」에 따라 문서의 작성 및 처리, 보존에 관한 기본사항을 정하여 전자문서를 관리하고 있으며, 생성된 전자문서를 「정보공개운영지침」에 따라 공개, 부분공개, 비공개로 분류하여 투명하게 관리하고 있다.

●★□★□은 「문서규정」에 따라 문서의 모든 처리절차가 전자적으로 처리 되도록 전자문서 시스템을 운영하고 있으며, 이에 대한 보안조치를 담당하고 있다.

2. 관계법령 및 판단기준

★□□은「문서규정」 제3조(정의)에 따라 전자문서²⁾에 관한 사무를 주관하는 “문서주관팀”으로서 제29조(문서관리부서)에 따라 전담자(★□□)와 문서책임자(각 부서)를 지정하여 소관 업무인 문서관리를 철저히 하여야 하며, 동규정 제2조(적용범위 및 시행세칙)를 준용하여 전자문서의 처리 절차(공람 및 열람 등), 분류 기준(1~3등급) 등 문서관리에 필요한 세부 사항을 시행세칙에 반영하여 안전하고 효율적인 문서관리를 하여야 한다.

이에 ●★□★□은 동규정 제7조(문서의 전자적 처리)에 따라 문서의 모든 처리 절차(공람·활용 등)를 전자문서 시스템상에서 전자적으로 처리되도록 조치하여 보안관리를 하여야 하며, 지속적으로 전자문서 시스템을 개선하여야 한다.

2) 문서규정 제13조(기안) 1항 ‘문서의 기안은 전자문서로 함을 원칙으로 한다.’에 따라 전자문서 관리가 주요 업무임.

3. 감사결과 확인된 문제점

가. ★□□의 경우

★□□은 「문서규정」에 따라 전자문서의 총괄 관리부서로 명시되어 있음에도 불구하고 전담자(★□□)는 지정하여 문서의 배포 및 접수처리는 정상적으로 운영하고 있으나, 각 부서의 전자문서 관리를 위한 문서책임자(각 부서)를 별도로 지정하지 않았으며, 그 역할과 책임에 대해서도 구분하지 않고 있다.

또한 규정 및 시행세칙에 전자문서의 등급별 설정 기준을 수립하지 않은 채 「정보공개운영지침」에 근거하여 비공개 사유에 해당하는 문서의 경우는 1등급으로 지정하고, 2등급과 3등급의 문서는 명확한 기준 없이 각 부서 팀장의 재량으로 동일 부서만 열람이 가능하다고 판단한 경우는 2등급, 전직원이 열람 가능하다고 판단한 경우는 3등급으로 분류하여 운영하도록 관리하고 있어, 전자문서 분류의 일관성을 저해하였다.

더욱이 공람 및 열람에 대한 처리 절차, 기준, 방식 등에 관한 세부 운영지침 등을 마련하지 않고 단지 편리성을 이유로 【표 1】과 같이 ●★□★□의 IT지원센터를 통해 관행적으로 처리하여 문서주관부서로서의 책임을 다하지 않았다.

【표 1】 전자문서 공람 신청 및 승인 처리 절차

순서	내용	신청 및 처리 주체

이는 「내부통제운영지침」 제8조(이행부서)에 따라 ★□□이 소관 업무인 전자문서 관리 및 소관 부서에 대한 내부통제를 소홀이 한 것으로, 규정 개정 등을 통해 전자문서 관리에 실효성을 확보하여 내부통제를 강화할 필요가 있다.

관련부서 의견

이에 대해 ★□□은 해당사실에 대해 이견이 없으며, 향후 관련부서(●★□★□)와 협의를 통해 보다 효율적인 업무처리를 위한 개선방안을 검토하고, 전자문서 관리에 필요한 세부 기준을 명확하게 수립하는 등 규정 현행화를 통해 업무불편을 해소할 것이라고 답변하였다.

나. ●★□★□의 경우

●★□★□은 「문서규정」에 따라 【그림 1】과 같이 최초 기안자(㉠공람자)가 결재를 득한 후 공람할 직원(㉢공람지정자)을 정한 후 공람을 할 수 있으며, 공람 처리된 문서는 전자문서 시스템(㉠공람자, ㉢공람지정자, ㉡열람 일시)에 자동으로 기록되도록 설정하여 공람 및 열람 등 문서 처리절차를 전자적으로 하고 있다.

【그림 1】 전자문서 시스템상 공람 및 열람 기록

㉠공람자	㉢공람지정자	㉡열람 일시
[Blank area with diagonal lines]		

그러나 현재 전자문서 시스템은 등급에 상관없이 최초 기안자(공람자), 결재권자(결재라인에 포함된 자) 뿐만 아니라 공람지정자도 다시 제3자에게 공람을 할 수 있는 권한이 부여되어 있어, 인사발령으로 부서가 변동된 이후에도 업무와 상관없이 상시적으로 문서를 공람, 열람할 수 있는 과도한 권한이 부여되어 있기에 정보 유출 및 남용 등의 문제가 발생될 수 있는 시스템상의 문제점이 존재한다.

특히 1등급 문서의 상당수가 「정보공개운영지침」에 따른 개인의 사생활 보호에 해당하는 정보임을 감안할 때 유출시 개인정보 침해 사고로 이어질 수 있기에 더욱더 시스템을 통해 강화된 보안조치를 하여야만 한다.

이에 1등급 문서에 대한 시스템적 보안조치를 확인하기 위해 감시기간 동안 IT지원센터³⁾를 통해 공람처리한 1등급 문서⁴⁾를 검토한 결과, 【표 2】와 같이 ●★□★□의 업무 담당자가 전자문서 시스템 관리자 계정(□●★, ★★□)을 이용하여 임의로 공람 처리한 내역이 다수 확인되어 절차 개선이 필요하다.

【표 2】 IT지원센터에 요청 없이 공람 처리한 내역(1등급 문서)

연 번	구 분	1등급 공람문서	공람을 처리한 계정 ⁵⁾ (●★□★□ 업무담당자)	공람요청일	열람
(내용 없음)					

관련부서 의견

이에 대해 ●★□★□은 전자문서의 공람처리는 정보화업무지침 제61조 2항 1호에 따라 IT지원센터를 통해 요청받아 처리한 것이며, 【표 2】의 경우 긴급 공람 요청건으로 유선으로 선처리 후 IT지원센터에 등록을 하여야 했으나 행정 처리가 이루어지지 않은 것이라고 답변하며, 향후 공람권한과 관련하여 전자문서 시스템 기능 개선을 검토하겠다고 하였다.

하지만 긴급으로 공람처리한 1등급 문서 중에는 개인정보도 포함되어 있어 정보 유출 및 개인정보 침해소지를 사전에 방지하기 위해 실제 열람한 문서⁶⁾ 이외는 회수처리 하여 보안관리를 강화하도록 처분요구하기로 한다.

3) 최초 기안자, 결재권자, 공람지정자가 공람한 내역도 상당수 존재하나, 별도의 절차나 기준이 없이 발생된 것임으로 제외하고, ★□□에서 ●★□★□의 IT지원센터를 통해 요청하여 처리한다고 답변한 관행적 절차의 문제점에 대해 개선하는 것을 중점으로 검토함

4) 2등급, 3등급 문서도 공람절차 없이 이루어지고 있어 개선이 필요하나, 유출시 개인정보 침해사고가 발생할 수 있는 1등급 문서로 한정하여 검토함

5) ●★□★□ 전자문서 시스템 공람처리 담당자: □★□, □★□

6) 공람처리한 총 □★□건 이중 실제 열람한 건수는 ★건으로 업무상 필요에 의한 것으로 보기 어려움

조치할 사항

★□□은

【개 선】 전자문서 등급별 문서 분류 기준과 공람·열람 처리 절차를 포함, 관련 기준 및 방식 등을 명확하게 수립하여 문서관리 규정 및 지침을 개정하고 문서주관팀으로서의 역할과 책임을 재정립하여 내부통제를 강화해 주시기 바랍니다.

●★□★□은

【권 고】 ①전자문서 시스템상 공람된 1등급 문서중 열람하지 않은 문서는 즉시 회수조치 하여 주시고, ②★□□과 협의하여 1등급 문서의 공람 요청시 열람기간 제한 및 인사발령시 1등급 열람 권한 회수, 재공람 불가 기능 추가 등 전자문서 시스템을 개선하여 운영하시기 바랍니다.

한국체육산업개발주식회사 감사실장

개 선 · 통 보

제 목 개인정보보호시스템별 접근권한 관리 개선 필요

관 계 부 서 ●★□★□

내 용

1. 업무개요

●★□★□은 기관의 정보화 업무를 관리하는 주관부서로서 「개인정보보호법」 및 「개인정보보호법 시행령」에 따라 정보시스템내 개인정보의 체계적인 관리와 보호조치 업무를 수행하고 있다.

2. 관계법령 및 판단기준

●★□★□은 「개인정보보호법」 제10조(시행계획)에 따라 매년 개인정보보호 시행계획을 수립하고 「개인정보보호법」 제29조(안전조치의무), 「개인정보보호법 시행령」 제30조(개인정보의 안정성 확보 조치) 등에 따라 개인정보의 안전한 관리 및 보호조치 이행을 위해 기관 특성에 맞게 내부관리계획을 현행화하고 있다.

특히 기관이 보유하고 있는 개인정보⁷⁾의 안정성 확보 조치를 위해 개인정보처리 시스템의 접근권한 관리 방침을 수립하여 이용자 본인확인, 접근권한 관리 기준 및 절차 등을 정하고, 이에 따라 개인정보처리시스템별 접근권한의 신청 절차 및 부여 기준 등 세부관리 방안을 수립하여 운영하고 있다.

이에 ●★□★□은 개인정보보호 주관부서로서 법률에 근거하여 자체 수립한 개인정보보호 시행계획·내부관리 계획·세부관리 방침 및 방안을 준수하여야 하며, 기관의 개인정보의 분실, 도난, 유출 및 훼손 방지를 위해 개인정보보호시스템의 접근권한을 최소한으로 부여하고 철저하게 관리하여야 한다.

7) 기관이 보유하고 있는 개인정보파일 현황: ①★□□●, ②□□●, ③□●, ④★□□

3. 감사결과 확인된 문제점

●★□★□은 개인정보보호와 관련하여 수립한 계획 및 방침 등에 담당자 (a~d)를 【표 1】과 역할과 책임을 구분하여 용어를 정의하였다.

【표 1】 개인정보보호 관련 용어 정의 현황표

--

특히 개인정보처리시스템 접근권한 기준 및 부여, 관리 절차에 대한 담당자 (a~d) 역할 등을 【표 2】와 같이 세부적으로 분류하여 관리하고 있다.

【표 2】 접근권한 기준 및 부여, 관리 절차(세부관리 방안 中)

구분	주요 내용

그러나 이에 대해 검토한 결과, 우선, 개인정보보호 시행계획, 내부관리계획, 관리 방침, 세부관리 방안의 담당자(㉠~㉣) 용어의 정의가 통일되지 않아 역할과 책임을 명확하게 구분하기 어려운 문제점이 확인되었다.

다음으로 업무별 최소한의 접근권한 범위의 기준이 명확하게 수립되어 있지 않아, ㉢부서별 팀장⁸⁾이 팀내 직원이 업무시 접근해야 할 개인정보가 무엇인지, 어떤 직원이 무슨 접근권한을 가지고 있는지 등을 확인할 수 없었으며, 만약 과도한 권한을 부여한 경우에도 즉시 회수 하는 것도 불가능 하기에 결국 관행적으로 업무 담당자의 요청에 따라 접근권한을 부여 할 수 밖에 없는 한계가 존재하였다.

이로 인해 개인정보보호 업무를 전담하는 ㉠총괄관리자(●★□★□), ㉢부서별 팀장(●★□★□), ㉡시스템 관리자(●★□★□ ●★□★□)도 실제로 업무별 접근권한이 기준에 맞게 최소한으로 적정하게 차등부여 되었는지, 불필요한 계정 등이 즉시 회수조치 되었는지 등을 실시간으로 확인할 수 없어 【표 3】과 같이 퇴사한 직원의 접근권한이 회수되지 않은 것이다.

【표 3】 퇴사자 개인정보 접근권한 미회수(2025년 10월 31일 기준)

연 번	성 명	사 번	접근권한 그룹명	취급가능한 개인정보	부여일	퇴사일
[Table content is crossed out with a large X]						

이는 접근통제에 대한 모니터링이 적절하게 이루어지지 않은 것이며, 인사발령시 자동으로 처리가 되지 않는 등 시스템적인 문제로 인해 발생한 것으로 개인정보 보호를 위해 개선대책이 필요하다고 판단된다.

8) 접근권한에 대한 부서별 팀장 답변 中 세부 기준 및 모니터링 방식 필요 등 개선방안 의견 참고

관련부서 의견

이에 대해 ●★□★□은 해당사실에 대해 이견이 없으며, 특히 확인된 □★□의 비정상적인 경우(로그인은 정상적으로 차단되어 접근이 불가능하나 일부 시스템 상의 오류로 데이터만 남아있음)에 대한 신속한 조치는 물론 접근권한 부여 이력 및 변경을 체계적으로 관리할 수 있도록 대책을 마련하고 주기적인 모니터링을 통해 재발방지를 하겠다고 답변하였다.

조치할 사항

●★□★□은

【개 선】 ①개인정보시스템별 접근권한과 관련하여, 업무별 최소한의 접근권한 기준, 범위 및 절차 등을 명확하게 재정립하여 주시고, 2026년도 시행계획(내부 관리계획), 방침 수립시 호칭체계 및 미비점⁹⁾을 보완하여 주시기 바랍니다.

②더불어 개인정보시스템별 접근권한에 대한 체계적 관리를 할 수 있는 실시간 모니터링 방안을 마련하여 접근통제를 강화하여 주시기 바랍니다.

【통 보】 전사적으로 개인정보시스템별 접근권한에 대한 내용과 기준, 범위 및 절차를 인지하고 준수할 수 있도록 관련 내용을 규정화(정보화업무지침에 포함)하는 등, 접근권한에 대한 내부통제가 적절히 이루어 질 수 있는 방안을 검토하여 주시기 바랍니다.

9) 개인정보처리시스템 접근권한 세부관리 방안 내 ‘붙임] 개인정보처리시스템별 접근권한 그룹’에 현재 기관이 보유하고 있는 ★□□가 포함되어 있지 않아 향후 포함하여 관리할 필요가 있음

한국체육산업개발주식회사 감사실장

현지조치

제 목 정보보안 관련 모니터링 소홀

관 계 부 서 ●★□★□

내 용

1. 업무개요

●★□★□은 「국가정보보안기본지침」에 따라 기관의 정보시스템 운영 및 관리를 통해 개인정보 유출 등 각종 보안사고 예방 및 대응에 대한 업무를 수행하고 있다.

2. 관계법령 및 판단기준

●★□★□은 「국가정보보안기본지침」 제6조(연도별 추진계획 수립)에 따라 정보시스템 내 서비스 현황 점검(●★□★, ●★□★), 정보시스템 내 불필요한 계정 및 서비스 포트 제거, 정보시스템 목록 현행화(□★, ●★□, ★□, ★□★□ 등)를 포함하여 연도별 정보보안 업무 추진계획 수립하고 있다.

이에 최근 사회적으로 이슈가 되고 있는 사이버 침해(●★□ 및 ●★ 개인정보 유출 사고 등)에 대한 대응체계 강화를 위해 최신 보안 취약점에 맞춰 기관내 운영중인 각종 보안장비의 정책을 항상 현행화하고 외부로부터 침입당할 수 있는 다양한 내·외부 경로에 대해 지속적으로 모니터링을 강화해야 한다.

3. 감사결과 확인된 문제점

그러나 감사기간 동안 현재 운영중인 보안장비를 점검한 결과, 【표 1】과 같이 ●★★□(●★□, ★□, ★□) 등 ★□와의 통신이 가능한 ★□●★된 정책이 확인되었다.

【표 1】예외 허용 정책 현황

연번	구 분	허용 IP
X		

이러한 ●★●★이나 ★●□ 등은 기관 내부의 정보를 유출할 수 있는 통로로 활용될 수 있어 정보보안 운영 매뉴얼의 <정보보안 위규 처리기준>에도 명시되어 있는 등 원칙적으로 허용되지 않는 정책이나 불가피하게 사용이 필요할 경우 ●□, ★●★, ●★●, ★●□● 등 더욱더 철저하게 관리하여야 하며, 특히 ●□ ★●가 종료된 경우 즉시 차단하여야 한다.

또한, 2025년도 정보보안 업무 추진계획에 따라 ㉠정보화 업무지침 수립, ㉢정보 보안 운영 매뉴얼 현행화, ㉣사이버 침해대응 매뉴얼 현행화, ㉤정보시스템 재해·재난 대비 절차서 현행화로 정보보호 관리체계를 강화하기로 하였으나, 확인결과 ㉢운영 매뉴얼과 ㉤절차서는 현행화되지 않았으며, 이에 따라 ●★●★●□와 ●★●★●□에 ★□★□(현재 사용하지 않음) ●★ 등 자산목록이 현행화 되어 있지 않았다.

이에 ●★●에 설정된 정책 중 ●★●★과 ●□● 등을 검토하여 기관 운영에 중단이 발생하지 않도록 정책을 재정비(차단, 삭제, 유지)하고, 더불어 ●★●★□ ●★●와 자산목록을 현행화하도록 현지조치 하였다.